МИНИСТЕРСТВО ПРОСВЕЩЕНИЯ
РЕСПУБЛИКИ БАШКОРТОСТАН

_____

(наименование образовательной организации)

Отделение _____

ОТЧЁТ
ПО ПРАКТИЧЕСКОЙ РАБОТЕ № 4

по дисциплине «Метрология, стандартизация
и сертификация в сфере ИТ»

Тема: «Стандарты и спецификации в области информационной безопасности и основы их сертификации»

Выполнил(а): _____

Группа: _____

Проверил(а): _____

Состав команды (при групповой сдаче):

_____

Уфа 2026

1 Цель и область анализа

Цель — выбрать нормативные требования и спланировать сертификацию для корпоративного мессенджера «SecureDev» с защищённым обменом файлами. Задачи: описать регуляторный ландшафт, выбрать три документа и составить дорожную карту [1–6].

Допущения: продукт обрабатывает учётные данные, сообщения и вложения без государственной тайны; внедрения у коммерческих и государственных заказчиков различаются. Для криптозащиты допускается интеграция готового СКЗИ. Ниже — проект решений, а не сведения о полученных сертификатах.

Приложение А — Регуляторный ландшафт

Аспект	**Решение для мессенджера**
Добровольная сертификация	Выбрана сертификация СМИБ компании по ГОСТ Р ИСО/МЭК 27001-2021. Область: разработка, эксплуатация и поддержка мессенджера; это не сертификат самого ПО [2].
Обязательное соответствие	Для ИСПДн определяются угрозы, уровень защищённости и меры по № 21; для ГИС — применимость № 117 и аттестации. Сам факт продажи мессенджера не означает универсальную обязательную сертификацию всего ПО [4–6].
Криптография	При необходимости сертифицированной криптозащиты применяют СКЗИ в сертифицированной конфигурации и по правилам ФСБ. TLS сам по себе не подтверждает выполнение требований к СКЗИ [6].
Продуктовая оценка	При поставке как СЗИ уточняются профиль защиты, функции, схема и требования ФСТЭК; оценка по Common Criteria относится к указанной версии и конфигурации продукта [3].

2 Органы и международное признание

Продолжение приложения А

Участник	**Роль и границы полномочий**
ФСТЭК России	Регулирует техническую защиту информации; организует сертификацию СЗИ в своей компетенции. Аттестация конкретной ИС — отдельная процедура.
ФСБ России	Регулирует криптографическую защиту и оценку СКЗИ в своей компетенции. Лицензия на деятельность не равна сертификату продукта.
Орган по сертификации	Принимает заявку, организует оценку, независимо принимает решение и выдаёт сертификат в пределах своей области. Для СМИБ проверяется компетентность и аккредитация по выбранной схеме.
Испытательная лаборатория	Проводит испытания продукта и оформляет протоколы; не подменяет решение органа по сертификации. Для выбранной СМИБ проводятся аудиты, а не сертификационные испытания продукта.
Росстандарт; ISO/IEC; МГС	Росстандарт утверждает национальные стандарты; ISO/IEC разрабатывают международные; МГС — межгосударственные. Эти организации не выдают сертификат на данный мессенджер.

Гармонизация требований облегчает сопоставление результатов, но не создаёт автоматического признания сертификата в Казахстане или Беларуси. До экспорта проверяют схему, область сертификата, соглашения о признании и требования государства назначения; для криптографии — отдельные ограничения [3, 6].

3 Матрица соответствия

Приложение Б — Три ключевых документа

Документ / объект	**Реализация и доказательство**
ISO/IEC 15408-2:2026. Information security, cybersecurity and privacy protection — Evaluation criteria for IT security — Part 2: Security functional components. Объект: продукт [3].	В задании по безопасности выбрать и обосновать компоненты FIA_UID/FIA_UAU (идентификация/аутентификация) и FAU_GEN (аудит). Мессенджер проверяет вход до доступа к файлам, журналирует входы, отказ доступа и скачивания. Проверка: отрицательные тесты и журнал. Само наличие функций не означает соответствие всей серии.
ГОСТ Р ИСО/МЭК 27001-2021. Информационная технология. Методы и средства обеспечения безопасности. Системы менеджмента информационной безопасности. Требования. Объект: процессы компании [2].	По п. 6.1.2–6.1.3 оцениваются и обрабатываются риски; утверждаются владельцы и заявление о применимости. Проектная мера: доступ администратора после согласования, пересмотр прав ежеквартально. Доказательства: реестр рисков, заявки, протоколы ревизии прав.
Приказ ФСТЭК России от 18.02.2013 № 21. Полное название — [4]. Объект: защита ИСПДн [4].	После определения уровня и угроз выбираются меры идентификации, управления доступом и регистрации событий. Пользователь видит только свои диалоги; роль администратора не даёт автоматического чтения вложений. Проверка: матрица ролей и тесты межпользовательского доступа.

Стандарты не предписывают конкретный фреймворк. Меры выбраны для данного проекта; персонал обучается в рамках СМИБ, но отдельная сертификация сотрудников здесь не заявляется.

4 Дорожная карта сертификации СМИБ

Выбран маршрут ГОСТ Р ИСО/МЭК 27001-2021. Сроки условные, сертификат не гарантирован: результат зависит от аудита и решения компетентного органа [2, 7].

Таблица 1 — План прохождения сертификации

Срок / этап	**Работы, ответственный, результат**
Недели 1–4. Подготовка	Руководство утверждает область и ресурсы. ИБ-команда выполняет gap-анализ, оценку рисков, внедряет меры. Результат: политика, реестр рисков, план обработки и записи выполнения.
Неделя 5. Заявка	Представитель компании проверяет область компетенции органа, подаёт заявку, согласует договор и программу аудита. Результат: принятое решение по заявке.
Недели 6–7. Экспертиза	Аудитор проводит этап 1: анализ документации и готовности. Внутренний аудит и анализ руководством должны быть выполнены до этапа 2. Результат: отчёт, перечень пробелов.
Недели 8–9. Аудит	Этап 2: интервью, выборочная проверка процессов и записей. Команда предъявляет доказательства работы мер; аудитор регистрирует несоответствия.
Недели 10–12. Исправления	Владельцы процессов устраняют причины несоответствий; орган проверяет достаточность действий. Результат: подтверждённое закрытие либо перенос решения.
Неделя 13. Решение	Независимый уполномоченный органа принимает решение. При положительном исходе выдаётся сертификат с областью и сроком действия, проверяется запись реестра.
После выдачи. Надзор	По программе схемы — надзорные аудиты; первый не позднее 12 месяцев от решения при схеме ISO/IEC 17021-1. До окончания цикла — ресертификация.

5 Контрольные вопросы и выводы

1) В чём различие ISO 27001 и ISO 15408? Первый оценивает систему управления ИБ в определённой области организации: риски, процессы и улучшение. Второй задаёт критерии оценки функций безопасности и доверия к конкретному объекту оценки. Сертификат СМИБ не доказывает отсутствие уязвимостей в каждой версии ПО [2, 3].

2) Какова роль МГС? Совет согласует межгосударственные стандарты и сотрудничество в стандартизации. Общие требования упрощают сравнение результатов, но сертификат РФ признаётся за рубежом только при наличии применимых механизмов признания; ГОСТ и сертификат — разные документы [6].

3) Принципы: беспристрастность, компетентность, объективность, конфиденциальность, прозрачность правил и возможность апелляции. Нарушение: аудитор проверяет собственное внедрение и скрывает конфликт интересов. Другая ошибка — решение без достаточных доказательств. Исправление: независимая группа, документированная выборка, независимое решение, процедура жалоб [7].

Выводы

Требования влияют на разделение ролей, модель доверия, интерфейс СКЗИ, контроль доступа к файлам и журналирование. Процесс разработки должен включать анализ угроз, проверку изменений и сохранение доказательств; сертификат не заменяет регулярную работу с уязвимостями.

Для коммерческой поставки сначала определяется договорный и правовой контекст. Для государственной — дополнительно категория системы, обязательные меры и оценка соответствия. Единого сертификата, автоматически разрешающего все варианты применения мессенджера, нет.

Тезисы защиты (2–3 минуты): объект сертификации → три требования матрицы → независимое решение → надзор. Процедура в отчёте спроектирована; заявка не подавалась, аудит и испытания не проводились.

6 Перечень использованных источников

1. Практические_работы__Методичка (2).docx. Практическая работа № 4.

2. ГОСТ Р ИСО/МЭК 27001-2021. Информационная технология. Методы и средства обеспечения безопасности. Системы менеджмента информационной безопасности. Требования. URL: https://base.garant.ru/403510768/.

3. ISO/IEC 15408-1:2026. Information security, cybersecurity and privacy protection — Evaluation criteria for IT security — Part 1: Introduction and general model; ISO/IEC 15408-2:2026 — Part 2: Security functional components. URL: https://www.iso.org/standard/15408-2.

4. Приказ ФСТЭК России от 18.02.2013 № 21 «Об утверждении Состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных».

5. Приказ ФСТЭК России от 11.04.2025 № 117 «Об утверждении Требований о защите информации, содержащейся в государственных информационных системах, иных информационных системах государственных органов, государственных унитарных предприятий, государственных учреждений». URL: https://base.garant.ru/412175328/.

6. Федеральные законы: от 27.12.2002 № 184-ФЗ «О техническом регулировании»; от 27.07.2006 № 149-ФЗ «Об информации, информационных технологиях и о защите информации»; от 27.07.2006 № 152-ФЗ «О персональных данных».

7. ISO/IEC 17021-1:2015. Conformity assessment — Requirements for bodies providing audit and certification of management systems — Part 1: Requirements.

Дата обращения к электронным источникам: 13.10.2026.